

TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN
KHOA MẠNG MÁY TÍNH VÀ TRUYỀN THÔNG

MỘT SỐ CÂU HỎI ÔN TẬP NỘI DUNG THI CUỐI KỲ

Môn học: **NT230 – Cơ chế hoạt động của mã độc**

Ngành: **An toàn thông tin**

Học kì 2 – Năm học 2024-2025

Ngày cập nhật: 10/06/2025

Phần I. TỔNG QUAN NỘI DUNG ÔN TẬP

Năng lực (NL)	Số câu hỏi ôn tập	Ghi chú
NL1 – Nhận biết, định nghĩa	3	Câu 1, 2, 11
NL2 – Hiểu nguyên lý, kỹ thuật	11	Câu 3, 4, 6, 9, 10, 15, 16, 17, 18, 19
NL3 – So sánh, phân tích kỹ thuật	7	Câu 3, 4, 5, 7, 8, 12, 17
NL4 – Ứng dụng, mô phỏng tình huống	7	Câu 6, 10, 13, 14, 18, 20, 21
NL5 – Phân tích – đề xuất giải pháp	5	Câu 6, 8, 13, 14, 21

Phần II. CÁC CÂU HỎI ÔN TẬP

1. Phân biệt virus, sâu máy tính (worm), botnet, ransomware, Ransomware as a service (RaaS), easter egg, salami attack, backdoor, rootkit, logic bomb, time bomb, trojan. Liên hệ ví dụ cụ thể cho từng loại.
2. Trình bày sự khác biệt giữa packer, crypter và protector trong ngữ cảnh sử dụng của các phần mềm độc hại.
3. Nêu khái niệm và trình bày sự khác biệt giữa dropper và downloader trong ngữ cảnh hoạt động của phần mềm độc hại.
4. Trình bày nguyên tắc chung của kỹ thuật Process Injection (tiêm tiến trình). Hãy liệt kê và phân loại các nhóm kỹ thuật con tiêu biểu của Process Injection theo cơ chế thực thi mã độc trong tiến trình mục tiêu.
5. Trình bày nguyên lý hoạt động của kỹ thuật Process Ghosting và Process Doppelgänger. So sánh điểm giống và khác nhau. Kỹ thuật nào có khả năng trốn tránh và nguy hiểm hơn? Vì sao?
6. Trình bày nguyên lý hoạt động và đặc điểm kỹ thuật Process Herpaderping. Mô tả một kịch bản tấn công dùng kỹ thuật này và đề xuất giải pháp phát hiện/ngăn chặn.

7. Giả định một hệ thống sử dụng EDR để giám sát tiến trình, hãy so sánh khả năng né tránh của Process Hollowing, Herpaderping và Doppelganging.
8. Trình bày các điểm mạnh và hạn chế của 4 kỹ thuật tiếm tiến trình: Hollowing, Herpaderping, Ghosting, Doppelganging. Đề xuất tiêu chí đánh giá hiệu quả né tránh (evasion effectiveness) các hệ thống phát hiện.
9. Trình bày ý nghĩa và nguyên lý của kỹ thuật Environmental Keying. Nêu ví dụ và phương pháp thực hiện.
10. EPO virus là gì? Nêu đặc điểm, mục đích, các loại EPO virus. Trình bày nguyên lý hoạt động của TLS-EPO.
11. Trình bày các giai đoạn điển hình trong vòng đời hoạt động của một mẫu mã độc (malware lifecycle). Nêu ví dụ minh họa.
12. So sánh phương pháp tấn công mã độc qua: (a) USB autorun, (b) macro Office, (c) Social Engineering. Phân tích nguy cơ thực tế và khả năng phát hiện.
13. Một hệ thống bị nhiễm mã độc qua lỗ hổng trình duyệt. Trình bày cơ chế tấn công và kỹ thuật phòng ngừa.
14. Trình bày cơ chế tấn công chuỗi cung ứng phần mềm (supply chain attack). Nêu ví dụ (SolarWinds, CCleaner, v.v.) và phân tích hậu quả.
15. Trình bày các kỹ thuật chống phân tích động trong các chương trình độc hại.
16. Nêu các chiến lược thường được sử dụng trong mã nguồn của mã độc nhằm chống phân tích tĩnh.
17. Trình bày mục đích và nguyên lý tạo mã độc đột biến. So sánh các chiến lược tạo biến thể: polymorphic, metamorphic, oligomorphic.
18. Trình bày ý nghĩa và ứng dụng của kỹ thuật sandboxing trong phát hiện mã độc. Liên hệ với mã độc có khả năng trốn tránh sandbox (evasive).
19. Trong bối cảnh phần mềm độc hại, nêu các rủi ro về bảo mật và quyền riêng tư đối với tài liệu Microsoft Office. Trình bày cách thức tấn công của mã độc sử dụng macro Office. Mã độc này trốn tránh sự phát hiện thông qua kỹ thuật nào?
20. Tấn công APT (Advanced Persistent Threat) là hình thức tấn công có chủ đích, được thực hiện bởi các tác nhân có tổ chức và nguồn lực. Trong quá trình tấn công, mã độc được sử dụng theo chuỗi nhằm thâm nhập, ẩn náu, và kiểm soát hệ thống mục tiêu trong thời gian dài. Yêu cầu:
 - Trình bày các giai đoạn chính trong chuỗi tấn công APT và vai trò của mã độc trong từng giai đoạn.
 - Phân tích kỹ thuật lẩn tránh/phân phối mã độc thường được sử dụng trong APT để vượt qua cơ chế phòng thủ hiện đại (AV, EDR, firewall).
 - Đề xuất một số giải pháp công nghệ hoặc chiến lược phát hiện sớm APT trong hệ thống tổ chức/doanh nghiệp. Các mô hình ngôn ngữ lớn (LLM) ngày càng được ứng dụng trong lĩnh vực an toàn thông tin.
21. Trong ngữ cảnh mã độc, LLM có thể hỗ trợ cả hai phía: kẻ tấn công có thể lợi dụng để sinh mã độc/phát triển công cụ tấn công, trong khi đội ngũ phòng thủ có thể dùng để phân tích, phát hiện hoặc phản ứng nhanh hơn với các mối đe dọa. Hãy:
 - Phân tích lợi ích và rủi ro khi sử dụng LLM cho bên tấn công (malware generation, evasion, automation).
 - Phân tích lợi ích và rủi ro khi sử dụng LLM cho bên phòng thủ (malware analysis, incident response, threat hunting).
 - Tham khảo sơ lược tại: <https://www.kellyroach.com/Papers/LLMMalware.pdf>